

Fidye Yazılımında Tedarikçi Hesabı Yetmedi: KVKK Kararı Adli Bilişimde Erişim Zincirini Öne Çıkardı

23 Ağustos 2026 | Ankara | Melike Özlem BİLGİLİ - Adli Mühendis

Kişisel Verileri Koruma Kurumunun Ağustos 2026'da kamuoyuna açılan karar özetleri arasında yer alan bir fidye yazılımı dosyası, siber saldırılarda yalnız saldırganın değil, saldırıya açılan erişim zincirinin de teknik olarak incelenmesi gerektiğini yeniden gündeme taşıdı. Kurulun 21 Temmuz 2022 tarihli ve 2022/711 sayılı karar özetine göre otomotiv güvenlik ve elektronik sistemleri üretimi yapan bir veri sorumlusunun sunucuları fidye yazılımıyla şifrelendi; saldırganlar bazı verileri ele geçirerek kendi bloglarında yayımladı ve ihlalden 660 kişi etkilendi.

Kurul kararında, ilk sızma bakımından insan kaynakları departmanının kullandığı bir yazılımı yöneten hizmet sağlayıcının erişim bilgilerinin ele geçirilmiş olabileceğine ilişkin bulgulara yer verildi. Hizmet sağlayıcının 2003'ten beri kullandığı bir kullanıcı hesabının veri sorumlusunun ağındaki bir bilgisayara ilk sızma aracını yüklediği; daha sonra çalınan yönetici erişim bilgileriyle yanal hareket gerçekleştirildiği ve komuta-kontrol altyapısıyla iletişim kurulduğu aktarıldı.

İhlalde müşteri ve tedarikçi temsilcilerine ait iletişim bilgilerinin yanı sıra çalışanlara ait özlük ve bazı sağlık verileri ile müşterilerin satın alma portallarına erişim sağlayan şifre bilgilerinin de etkilendiği belirtildi. Kurul, veri güvenliğine ilişkin gerekli teknik ve idari tedbirlerin alınmadığı sonucuna vararak 6698 sayılı Kişisel Verilerin Korunması Kanunu kapsamında 500 bin TL idari para cezası uygulanmasına karar verdi.

NEDEN ÖNEMLİ? SALDIRININ BAŞLADIĞI HESAP İLE SORUMLULUK ALANI AYNI ŞEY DEĞİL

Dosyanın adli bilişim bakımından dikkat çekici yönü, saldırının bir dış hizmet sağlayıcı hesabıyla ilişkilendirilmesine rağmen incelemenin veri sorumlusunun kendi güvenlik mimarisine kadar uzanması. Kararda ağ içinde yanal hareketin mümkün hale gelmesi, yönetici erişim bilgilerinin ele geçirilmesi ve saldırının altyapı boyunca ilerleyebilmesi teknik değerlendirmede önem taşıyan unsurlar arasında.

Bu yaklaşım, bir fidye yazılımı olayında "saldırı tedarikçiden geldi" tespitinin tek başına incelemeyi bitirmediğini gösteriyor. İlk erişim noktasından sonra saldırganın hangi yetkilerle ilerlediği, ağ segmentasyonunun bulunup bulunmadığı, eski veya sürekli açık hesapların nasıl yönetildiği, ayrıcalıklı hesapların korunması ve olayın ne zaman tespit edildiği ayrı delil başlıklarıdır.

ADLİ BİLİRKİŞİ DEĞERLENDİRMESİ

Benzer bir uyuşmazlıkta bilirkişi incelemesi öncelikle ilk erişim, yetki yükseltme, yanal hareket, veri çıkarma ve şifreleme aşamalarını ayrı ayrı zamanlandırmalıdır. Active Directory ve kimlik doğrulama kayıtları, VPN ve uzaktan erişim logları, ayrıcalıklı hesap hareketleri, EDR/SIEM kayıtları, güvenlik duvarı ve ağ akış kayıtları, C&C bağlantıları, dosya erişim ve kopyalama izleri ile yedekleme sistemlerinin olay kayıtları korunmalıdır.

Özellikle hizmet sağlayıcı hesabının yaşı, son kullanım tarihleri, verilen yetkilerin kapsamı, çok faktörlü kimlik doğrulama kullanılıp kullanılmadığı, hesabın yalnız gerekli sistemlere erişip erişemediği ve tedarikçi erişiminin periyodik olarak gözden geçirilip geçirilmediği teknik olarak doğrulanmalıdır. Saldırganın kullandığı hesabın tespit edilmesi, hesabın sahibinin saldırıyı gerçekleştirdiğini göstermez; kimlik bilgisi hırsızlığı ile gerçek kullanıcı faaliyeti birbirinden ayrılmalıdır.

Veri sızıntısı bakımından da yalnız saldırganın "veriyi aldım" iddiası yeterli değildir. Dosya erişim zamanları, dışa veri transferi, ağ trafiği, bulut veya uzak depolama hareketleri, sıkıştırılmış arşiv izleri ve yayımlanan örneklerin kurum verileriyle eşleşmesi birlikte değerlendirilmelidir. Teknik bilirkişi, bu bulgular üzerinden olay zincirini ortaya koymalı; hukuki sorumluluk veya suç konusunda hüküm kurmamalıdır.

BENZER OLAY | OTOMOTİV YAN SANAYİ KARARI

KVKK'nın 6 Mart 2024 tarihli ve 2024/415 sayılı başka bir kararında, merkezi Fransa'da bulunan sunuculara yönelik LockBit fidye yazılımı saldırısının Türkiye'deki sekiz sunucuya da yayıldığı; Kurulun ağ bileşenleri arasında erişim sınırlandırılması ve ağların alt ağlara bölünmesi yönündeki tedbirleri değerlendirdiği görülüyor. Bu dosya, fidye yazılımının ilk giriş noktasından sonra ağ içinde yayılmasının ve segmentasyonun adli-teknik incelemedeki önemini göstermesi bakımından güncel dosyayla anlamlı benzerlik taşıyor.

KAYNAKLAR

- Kişisel Verileri Koruma Kurumu, 21.07.2022 tarih ve 2022/711 sayılı Karar Özeti: "Otomotiv güvenlik ve elektronik sistemleri üretimi yapan veri sorumlusu tarafından Kurula intikal ettirilen veri ihlal bildirimine istinaden yürütülen inceleme."
- Kişisel Verileri Koruma Kurumu, 06.03.2024 tarih ve 2024/415 sayılı Karar Özeti: otomotiv yan sanayi üretim firmasına yönelik LockBit fidye yazılımı saldırısı.
- 6698 sayılı Kişisel Verilerin Korunması Kanunu, özellikle veri güvenliğine ilişkin 12. madde ve idari yaptırımlara ilişkin 18. madde.
- Vircon Legal, Ağustos 2026: KVKK'nın kamuoyuna açılan 47 karar özetine ilişkin bağımsız değerlendirme.